

Firewalls, proxies, access control lists, IDSs, and honeypots

1. Firewall

Definition:

A **firewall** is a security system (hardware or software) that controls incoming and outgoing network traffic (IP addresses) based on predetermined security rules.

Blacklist - a list of prohibited source IP addresses.

An **IP address** - unique numerical label - such as 192.168.1.1 - assigned to every device connected to a computer network that uses the Internet Protocol for communication.

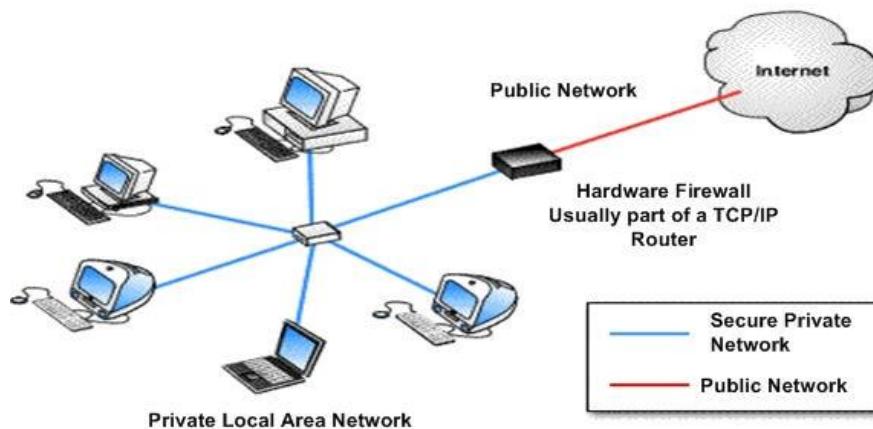


Figure 1. Firewall¹

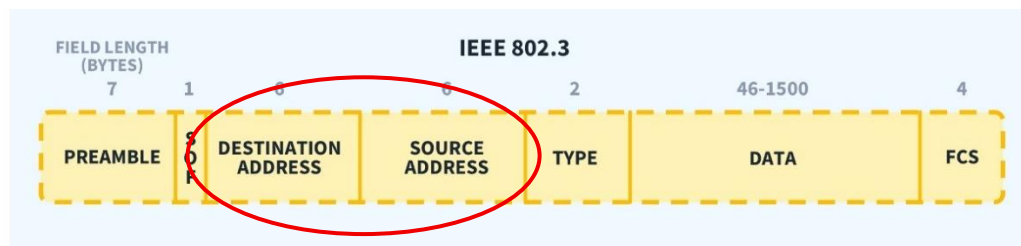


Figure 2. IP packet structure²

¹ <http://www.vicomsoft.com/knowledge/reference/firewalls1.html>

² <https://www.cbtnuggets.com/blog/technology/networking/what-is-ethernet-frame-format>

Purpose:

- Block unauthorized access
- Allow legitimate communication
- Protect networks from malware and intrusions

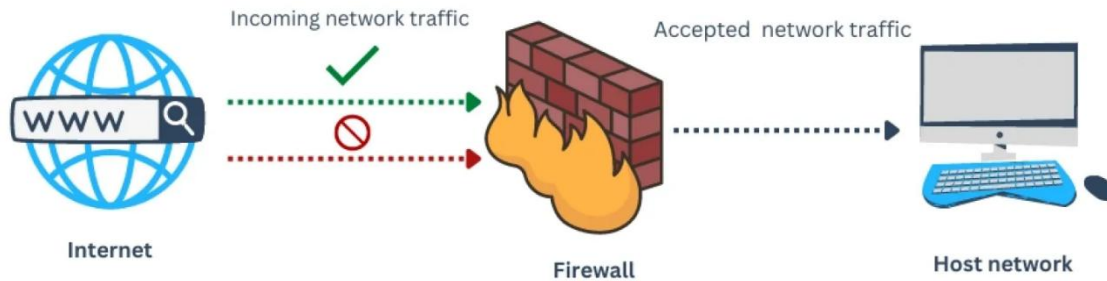


Figure 2. The process of firewalls³

Types and categories of firewalls

By location of installation:

Type	Description	Example
Hardware	Standalone device, often in routers / gateways	Cisco ASA, Fortinet, WatchGuard
Software	Installed on a device/PC - personal firewall	Windows Defender Firewall
Cloud-based	Hosted remotely – in cloud; scalable for large networks	AWS WAF, Cloudflare firewall

³ <https://research.aimultiple.com/firewall-vs-proxy/>

By filtering method:

Category	Function
Packet filtering	Analyzes IP headers (source/destination IP addresses, port – entry point, protocol type (for example, TCP/UDP)).
Stateful inspection	Tracks active connections. Allows return traffic if request was legitimate. Characterized by the existence of a state table in which the firewall keeps records of the current state of connections.
Application-layer	Filters specific applications (HTTP, FTP) based on content.
Network Address Translation (NAT)	Translates the addresses of the computers in the private network to one or more public IP addresses and thus hides the identity of the computers in the local network.
Next-generation firewalls	Combine multiple features: deep packet inspection, antivirus, IDS/IPS.

Protocols – corresponding (reserved) port numbers

HTTP (HyperText Transfer Protocol) → Port **80**

HTTPS (HTTP Secure) → Port **443**

FTP (File Transfer Protocol) → Port **21**

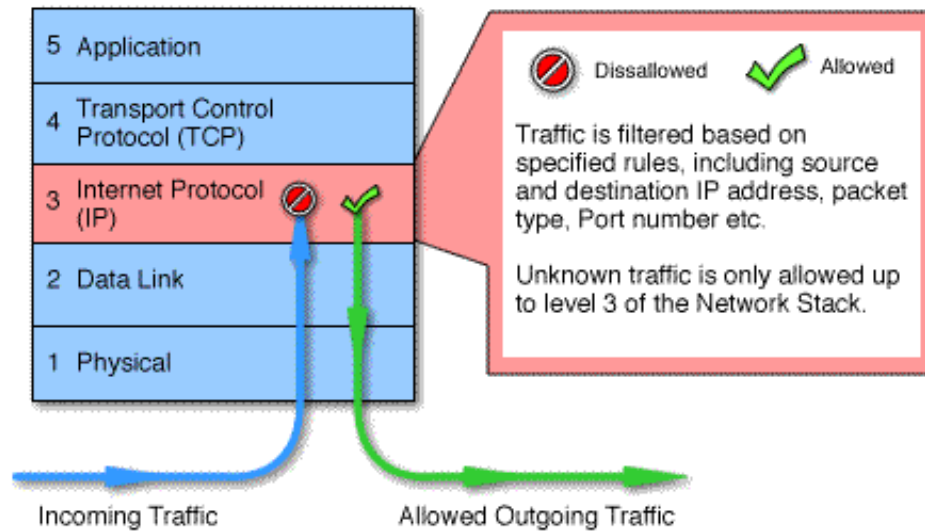
SSH (Secure Shell) → Port **22**

DNS (Domain Name System) → Port **53** (TCP/UDP)

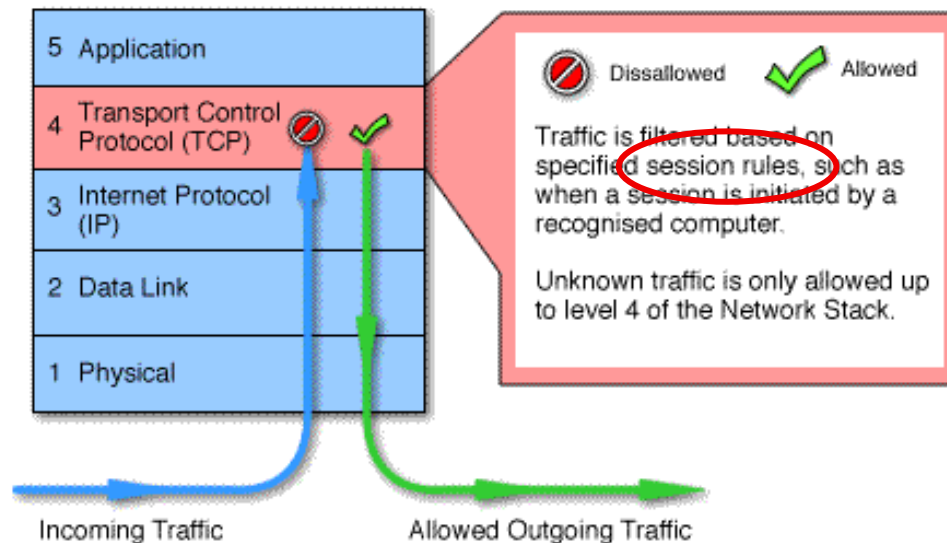
SMTP (Simple Mail Transfer Protocol) → Port **25**

Packet filtering:

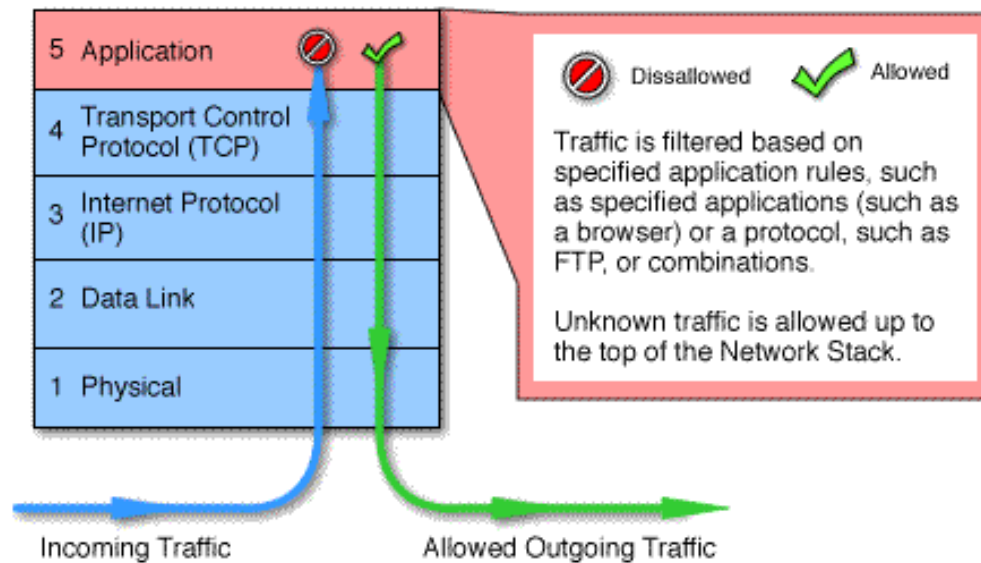
OSI (Open Systems Interconnection) – TCP/IP model is a **set of layers** that explains how different computers communicate over a network.



Circuit-level gateway:

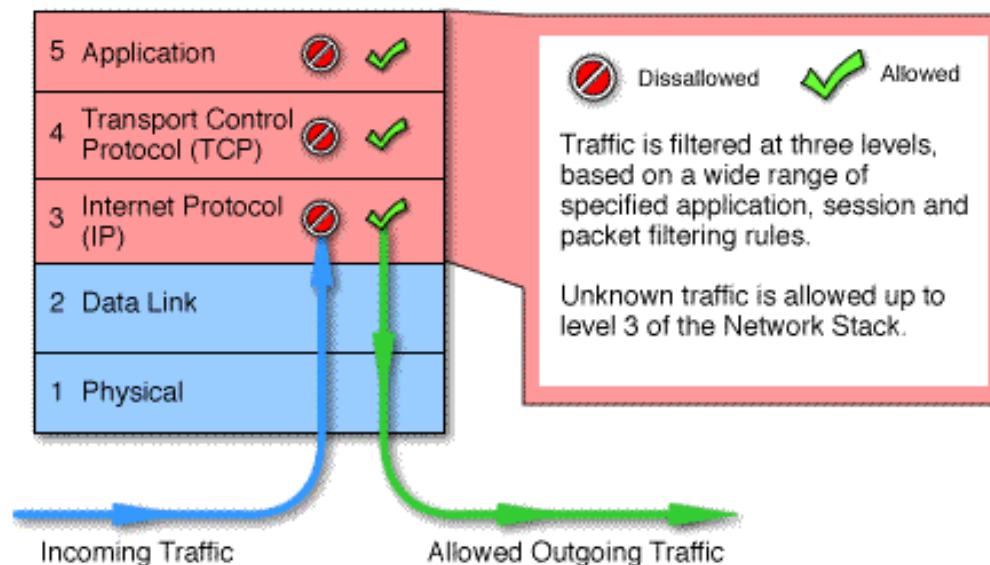


Application level gateway:



Stateful inspection:

It combines the features of the previous three firewalls.



Integrated firewall

An existing device (e.g. router) supplemented with firewall services. Integrated routers provide basic firewall services (packet, application, website filtering).

Types of packet filtering

Stateless firewall - Discards the packet if it does not have enough information about what to do with it. Most firewalls of this type **leave ports greater than 1024 open** to allow a reply to be sent to the computer that sent the request. Trojan horses can exploit these ports - a serious security flaw!

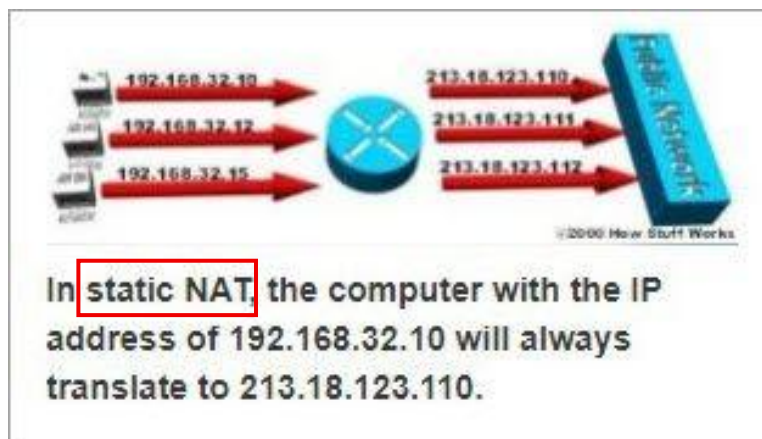
Stateful firewall - Monitors the state on the network layer (remembers the connection requests) and uses it when making decisions. It is characterized by the existence of a **state table**, i.e. a table in which the firewall keeps records of the current state of connections. Firewalls of this type allow responses to be sent to computers that have established a connection, but ports remain open only as long as necessary. It **only analyzes the packet header**.

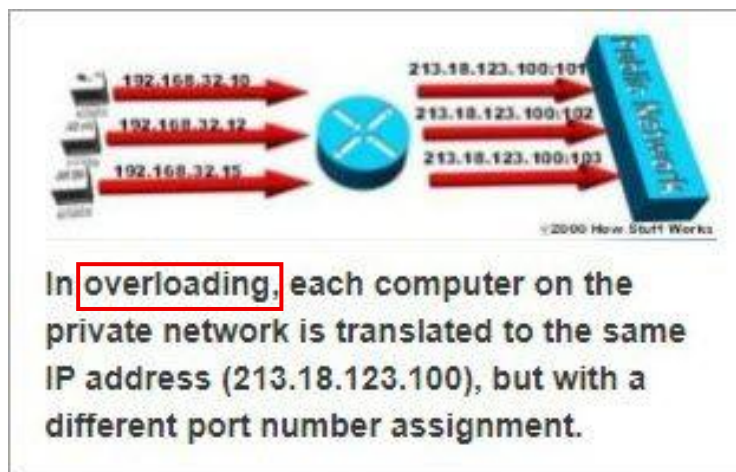
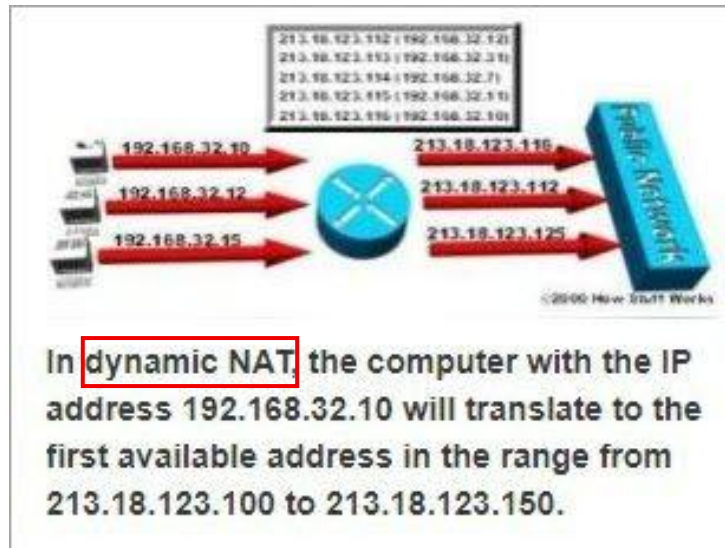
Network Address Translation (NAT)

NAT **hides information** about computers in a private network from attackers on the Internet.

When passing a packet through a firewall, NAT hides the IP addresses of computers from the private network, **translating them into the address of the firewall**.

In addition to the protective function, NAT enables the **saving of public IP addresses**, because one public IP address, with the use of different port numbers, can be translated into a larger number of private IP addresses.





Task 1:

A firewall uses NAT with 1 public IP address and different port numbers.

If:

- Each internal device uses 1 unique port
- Available port range: 1024–65535

How many internal devices can be supported simultaneously?

Solution:

Calculate number of available ports:

$$65535 - 1024 + 1 = \mathbf{64512 \text{ ports}}$$

Key idea:

With NAT (specifically PAT – Port Address Translation):

- Each **public IP × available ports = total connections**

2. Proxy server

Definition:

A **proxy server** acts as an intermediary between clients and the internet (web site), forwarding requests and masking client identity.

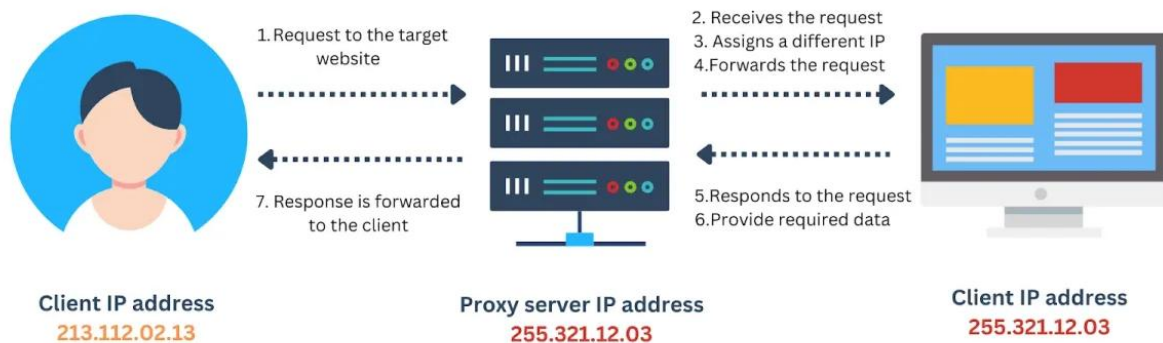


Figure 2. Process representation of proxy servers⁴

Main functions:

- Hides client IP address
- Filters web traffic (e.g., block social media)
- Caches web pages for faster access - remembers the last loaded web page

⁴ <https://research.aimultiple.com/firewall-vs-proxy/>

- Records logs and monitors usage
- Controls access by user/group/time

Proxy services

Filtering and NAT solve some of the problems of connecting local networks to the Internet, but considering that they **only analyze** and possibly change the packet header and not its content, they **do not provide complete control of data** passing through the firewall.

An **application layer proxy** prevents this problem by allowing network layer protocol (IP, ICMP (eg. ping)) traffic to be completely denied and **only higher layer protocol traffic** (HTTP, FTP and SMTP) **allowed**.

The application proxy **analyzes the complete packet and monitors the state of the connection**.

The application layer proxy is a client-server architecture, specific to the specific protocol being used.

Types of proxies:

Type	Description
Forward proxy	Client → proxy → Internet (used by users)
Reverse proxy	Internet → proxy → Web server (used by services)
Transparent proxy	Invisible to users, auto-applies policies

Example: A school uses a forward proxy to block gaming websites.

3. Access Control Lists (ACLs)

Definition:

An **Access Control List (ACL)** is a **set of rules on a router or firewall** that defines what traffic is allowed or denied.

ACL rule format:

- Permit/deny
- Protocol (e.g., TCP, UDP, ICMP)
- Source IP
- Destination IP
- Port number

Types of ACLs:

Type	Description
Standard	Filters only by source IP (1-99)
Extended	Filters by source IP, destination IP, protocol, port (100-199)

Example:

```
access-list 100 permit tcp 192.168.1.0 0.0.0.255 eq 80 10.0.0.0  
0.255.255.255
```

wildcard mask

A **wildcard mask** is a value used mainly in ACLs to define **which IP addresses should match a rule and which bits can vary**.

A wildcard mask works like a filter:

- **0 → must match exactly**

- **1 → can be anything**

Keywords can be used instead wildcards:

- host (for a single IP)
- any (for all IPs)

Examples:

`access-list 10 permit host 192.168.1.5` ← no wildcard needed

`access-list 10 permit any` ← no wildcard needed

Field	Meaning
<code>access-list 100</code>	Extended ACL
<code>permit</code>	Allow traffic
<code>tcp</code>	TCP protocol
<code>192.168.1.0/24</code>	Source network
<code>eq 80</code>	Source port = 80 (HTTP)
<code>10.0.0.0/8</code>	Destination network

Task:

Given the ACL:

```
access-list 101 permit tcp 192.168.1.0 0.0.0.255 10.0.0.0
0.0.255.255 eq 443
```

Determine whether the following packet is allowed:

- Source IP: 192.168.1.45
- Destination IP: 10.0.5.10
- Protocol: TCP

- Port: 443

Solution:

Step 1: Check source network

Wildcard:

192.168.1.0 0.0.0.255 → range: 192.168.1.0 – 192.168.1.255

192.168.1.45 → matches

Step 2: Check destination network

Wildcard:

10.0.0.0 0.0.255.255 → range: 10.0.0.0 – 10.0.255.255

10.0.5.10 → matches

Step 3: Check protocol and port

- Protocol = TCP ✓
- Port = 443 ✓

Final answer: Packet is PERMITTED.

Benefits:

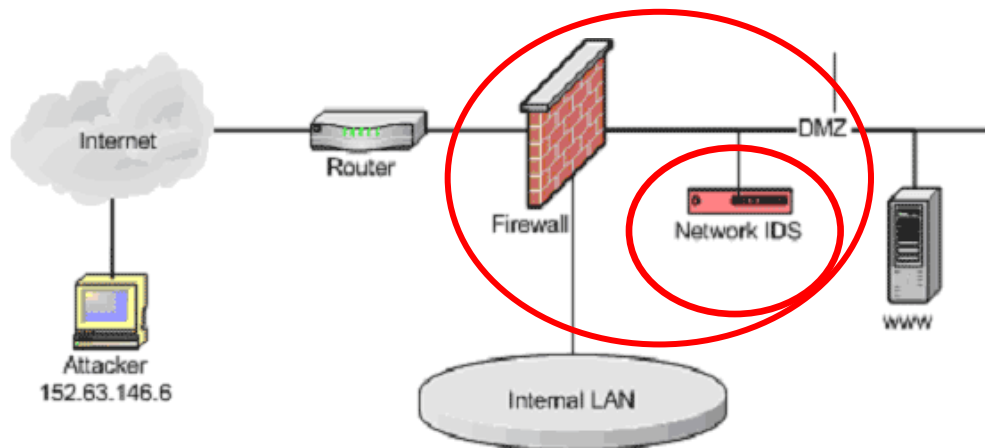
- Precise control of allowed/not allowed traffic
 - Helps segment networks
 - Reduces the *attack surface* - the total number of all possible entry points where an unauthorized user can try to access, extract data from, or interfere with a system
-

4. IDS (Intrusion Detection System)

Definition:

An **IDS** monitors network traffic or system logs for suspicious activity or policy violations.

An IDS should detect all types of malicious network traffic and computer usage that cannot be detected by a conventional firewall. **Firewall analyzes only the IP packet header** (source and destination addresses) and, based on the filtering rules, allows the packet to pass through the destination network interface or rejects the packet. **Firewall does not analyze the content of the packet** → it cannot prevent attacks such as buffer overflow or SQL injection that are stored in the content of the packet.



The location of the IDS installation is immediately behind the firewall.

Types of IDS:

Type	Function
NIDS	Network-based IDS (e.g., Snort, Suricata, Zeek (former Bro))
HIDS	Host-based IDS (e.g., OSSEC)
Misuse detection	Detection of known attacks + insider attacks. Detection is based on "signatures" and rules of known attacks.

Type	Function
Anomaly detection	Concentrates on unusual activity (anomaly) that may indicate an intrusion.

What IDS can detect?

- Port scanning
- Malware patterns
- Brute-force login attempts
- Unexpected changes in files or logs

IDS is **passive** - it **detects** but doesn't block.

5. Honeypots

Definition:

A honeypot is a **decoy system** designed to lure attackers, with the aim of studying their methods.

Characteristics:

- Divert attackers away from real systems
- Logs only intrusion attempts (attacks) for analysis
- Understand threats and attack patterns
- For detecting and tracking attacks and intrusions
- For research purposes: discovering new attack methods and tools, creating statistics

Examples:

- A fake login page collecting brute-force attempts
- A fake server mimicking a vulnerable database

Key benefit: Enhances threat intelligence without risking actual assets.

a) Low-interaction honeypot

A low-interaction honeypot is not a standalone machine (virtual machine), but rather an emulator program that emulates the services of an operating system.

Its advantage is that it is easy to install and configure. The risk is minimal with an emulated service.

The big advantage of this solution is that the attacker does not gain control over the operating system, since it is only emulated.

The attacker only obtains a limited amount of information, mainly transaction data, and collects some minor interactions.

These are mostly used in corporate systems and manufacturing industries.

b) High-interaction honeypot

High-interaction honeypots run real operating systems and services, not emulated ones.

These types of honeypots should be placed behind a firewall to reduce risks.

They are difficult to install and maintain, but they can provide a huge amount of information about the behavior and motivations of hackers.

They are mostly used for research.

Honeynet – A honeynet is a network of multiple computers that has the same functions as a honeypot.

Honeyfarm - a centralized set of honeypots and attack analysis tools. The essence of its operation is that a decoy network (honeynet) must be installed in a central location, and a honeypot must be installed at each site, the role of which is to immediately redirect suspicious activities to the central honeynet.

Key terms summary

Term	Definition
Firewall	A security system that controls incoming and outgoing network traffic
Packet filtering	Allows/blocks traffic based on IP and port info
Stateful inspection	Tracks ongoing connections for intelligent filtering
Proxy server	An intermediary between clients and the internet
ACL (Access Control List)	A set of router/firewall rules to allow or block traffic
IDS	A system that detects suspicious activity on a network or system
Honeypot	A decoy system used to lure and study cyber attackers